

INFORME DE PENTESTING ÉTICO

Trabajo práctico A08 — INSECUR S.A.

Estudiante: Felipe Villar Zuloaga

Fecha de entrega: 08/10/2026

Nota de integridad técnica: este borrador utiliza únicamente los resultados comunicados hasta el momento. Los elementos no verificados se identifican expresamente como pendientes.

1. Datos generales

Campo	Valor
Cliente	INSECUR S.A. (escenario académico)
Contratista / alumno	Felipe Villar Zuloaga
DNI	46.063.333
Usuario de TryHackMe	feliivillar97
Correo institucional	villarfelipe@uch.edu.ar
Sala obligatoria	Basic Pentesting y Pentesting Fundamentals
Rama de GitHub	villar-felipe
Fecha de cierre	08/10/2026
IP objetivo de la sesión documentada	10.64.182.213

2. Pre-pentesting

Alcance del trabajo

La evaluación se limita a la máquina o máquinas asignadas al estudiante dentro de la plataforma TryHackMe y a los servicios accesibles desde el entorno de laboratorio autorizado. Las direcciones IP deben asociarse a su sesión correspondiente y verificarse con la evidencia guardada. Quedan excluidos sistemas de terceros, redes públicas, infraestructura institucional no autorizada y cualquier activo ajeno al laboratorio.

Reglas de enfrentamiento (ROE)

Las pruebas se realizan con finalidad académica, dentro del alcance de TryHackMe y respetando los límites de la sala. Se prioriza la enumeración no destructiva, se registran los comandos y resultados, y se detiene cualquier prueba que pueda afectar servicios fuera del objetivo. No se deben publicar contraseñas, tokens, flags completas ni datos sensibles. Toda interrupción o comportamiento inesperado debe documentarse y comunicarse al docente.

Autorización

El trabajo se presenta como una práctica académica autorizada por la cátedra sobre los entornos indicados de TryHackMe. Esta declaración no extiende la autorización a sistemas reales ni a activos no incluidos en el alcance.

Metodología utilizada

Se adopta un flujo basado en las fases de PTES y en prácticas de NIST SP 800-115: definición de alcance, reconocimiento, escaneo, enumeración, validación controlada de hallazgos, análisis de impacto, recomendaciones y reporte. La metodología se adapta a los resultados efectivamente obtenidos; una herramienta ejecutada no implica por sí misma que una vulnerabilidad haya sido confirmada.

3. Ejecución del trabajo y evidencia disponible

3.1. Reconocimiento y conectividad

La sesión de laboratorio documentada tiene como IP objetivo corregida 10.64.182.213. Antes de entregar, verificar que esta IP coincida con las capturas y los archivos de bitácora. La evidencia de conectividad VPN se identifica como evidencias/reconocimiento/THM_VPN_Connection.png, sujeto a revisión del archivo final.

3.2. Escaneo de puertos y servicios

Se reportaron los siguientes servicios para una sesión: TCP/22 OpenSSH; TCP/80 Apache HTTP Server 2.4.41 sobre Ubuntu; TCP/445 Samba 4.15.13-Ubuntu; TCP/8080 Apache Tomcat 9.0.7. Estos datos se incluyen como resultados comunicados por el estudiante y deben contrastarse con el archivo de salida de Nmap correspondiente a la misma IP. No se afirma que las versiones identificadas sean vulnerables sin validación adicional.

3.3. Enumeración web

La enumeración con Gobuster comunicada para el servicio web de Tomcat en el puerto 8080 identificó las rutas /docs/ (HTTP 302), /examples/ (HTTP 302), /favicon.ico (HTTP 200), /host-manager/ (HTTP 302) y /manager/ (HTTP 302). Los códigos 302 indican redirección y no prueban por sí solos exposición de información ni vulnerabilidad. Debe conservarse bitacora/gobuster_tomcat.txt y una captura de las respuestas.

3.4. Validación de Tomcat Manager

Se mencionaron las credenciales tomcat:s3cret y el rol manager-gui, pero en la información disponible no se adjuntó una salida verificable que confirme el inicio de sesión ni los permisos efectivos. Por tanto, no se presenta como acceso confirmado. Antes de cerrar el informe, incorporar evidencia saneada del resultado HTTP y de los roles observados, sin publicar la contraseña. No incluir pruebas de ejecución remota si no se realizaron y documentaron.

3.5. Enumeración SMB

Se informó que se intentó enumerar el servicio SMB y validar un recurso anónimo denominado Anonymous. No se dispone aquí de una salida completa que confirme qué recursos eran accesibles ni qué archivos pudieron leerse. El acceso anónimo debe mantenerse como hallazgo pendiente de verificación hasta adjuntar el comando utilizado y su resultado. No se infiere acceso a datos sensibles sin evidencia.

3.6. Análisis de vulnerabilidades

En el borrador se mencionó Apache Struts 2/CVE-2017-9805 como posible línea de investigación. No se dispone de evidencia que confirme que el servicio ejecuta una versión afectada ni que la vulnerabilidad sea explotable en el objetivo. En consecuencia, no se clasifica como vulnerabilidad confirmada ni se asigna un CVE al hallazgo sin comprobar producto, versión, configuración y evidencia técnica.

4. Hallazgos por fase

Criterio de clasificación

Los hallazgos H-01 a H-04 reflejan los datos comunicados hasta el momento. H-03 y H-04 son hipótesis pendientes de evidencia; no deben contarse como vulnerabilidades confirmadas. Las severidades deben revisarse cuando se disponga de resultados verificables, configuración e impacto.

ID / fase	Descripción y estado	Componente / categoría	Severidad	Impacto CIA	Evidencia y herramienta	Salvaguarda / riesgo residual
H-01 / Escaneo	Servicios expuestos comunicados: SSH, HTTP, SMB y Tomcat. Confirmar con el archivo Nmap de la misma sesión.	TCP/22, 80, 445, 8080. Gestión de superficie de ataque.	Informativo hasta validar configuración e impacto.	No se demuestra impacto CIA por el mero hecho de que un puerto esté abierto.	Nmap; adjuntar bitacora/nmap_inicial.txt y bitacora/nmap_puertos.txt.	Restringir puertos a los orígenes necesarios, actualizar servicios y monitorizar. Riesgo residual: pendiente de revisión.
H-02 / Enumeración	Rutas estándar de Tomcat respondieron con 302 y favicon.ico con 200, según salida comunicada. No constituye vulnerabilidad por sí solo.	Tomcat 9.0.7 / configuración web.	Bajo o informativo; no confirmado como vulnerabilidad.	No demostrado.	Gobuster; bitacora/gobuster_tomcat.txt y captura por adjuntar.	Deshabilitar aplicaciones de ejemplo no necesarias y limitar paneles administrativos. Riesgo residual: pendiente.
H-03 / Enumeración	Posible acceso a Tomcat Manager mediante credenciales comunicadas, aún sin evidencia verificable adjunta.	Tomcat Manager / CWE-521 si se confirma uso de contraseña débil; no asignar hasta verificar.	Pendiente de verificación; no contabilizar como confirmado.	Potencial afectación de confidencialidad, integridad y disponibilidad si se confirma acceso administrativo indebido.	Validación HTTP autenticada y roles efectivos; ocultar secretos en la evidencia.	Cambiar credenciales predeterminadas, aplicar contraseñas únicas, mínimo privilegio y restricción por IP. Riesgo residual: no evaluable aún.
H-04 / Enumeración	Posible enumeración/acceso anónimo SMB reportado, pero falta salida que demuestre recursos y permisos efectivos.	Samba/SMB; CWE a determinar según la configuración demostrada.	Pendiente de verificación; no contabilizar como confirmado.	Potencial exposición de confidencialidad o alteración de integridad, según permisos reales.	Adjuntar salida saneada de smbclient/enum4linux y captura correspondiente.	Deshabilitar acceso anónimo si no es necesario; revisar ACL, permisos y segmentación. Riesgo residual: no evaluable aún.

5. Resumen ejecutivo de hallazgos

Resumen

Con la evidencia actualmente descrita no es responsable declarar vulnerabilidades explotadas ni asignar una cantidad definitiva de hallazgos críticos, altos, medios o bajos. El resumen se presenta de forma conservadora: los hallazgos de superficie de ataque y rutas se encuentran en revisión; el acceso administrativo a Tomcat y el acceso SMB anónimo permanecen pendientes de confirmación.

Severidad	Cantidad confirmada	IDs / observación
Crítico	0 confirmados	No hay evidencia aportada que permita clasificar un hallazgo como crítico.
Alto	0 confirmados	No hay evidencia aportada que permita clasificar un hallazgo como alto.
Medio	0 confirmados	Revisar H-03 y H-04 si la evidencia confirma permisos indebidos e impacto.
Bajo / informativo	0 vulnerabilidades confirmadas	H-01 y H-02 son observaciones técnicas; no se cuentan automáticamente como vulnerabilidades.
Pendientes de verificación	2	H-03 (Tomcat Manager) y H-04 (SMB anónimo).

6. Post-pentesting: recomendaciones

6.1. Recomendaciones técnicas

1) Confirmar inventario de puertos y versiones con Nmap de la sesión correcta. 2) Actualizar Apache, OpenSSH, Samba y Tomcat a versiones soportadas, después de verificar versiones exactas y compatibilidad. 3) Restringir el acceso a Tomcat Manager y Host Manager a redes administrativas autorizadas; deshabilitar aplicaciones de ejemplo y administración si no son necesarias. 4) Sustituir credenciales predeterminadas o débiles y aplicar mínimo privilegio a los roles de Tomcat. 5) Revisar recursos compartidos SMB, deshabilitar acceso anónimo no requerido y auditar permisos de lectura/escritura. 6) Aplicar filtrado de red, registros centralizados y alertas para intentos de acceso administrativo. 7) Repetir pruebas controladas después de la remediación y adjuntar evidencia de cierre.

6.2. Recomendaciones administrativas

Establecer una política de gestión de credenciales; inventariar y revisar periódicamente los servicios expuestos; formalizar el proceso de actualización y parcheado; capacitar a administradores sobre exposición de paneles; conservar bitácoras y capturas; y definir responsables y plazos de remediación según la criticidad validada.

6.3. Priorización

Prioridad inmediata si se confirma que credenciales predeterminadas permiten administración o que SMB expone datos: corregir credenciales, restringir accesos y revisar permisos. Prioridad siguiente: parcheado y reducción de superficie de ataque. Las prioridades deben ratificarse tras verificar los hallazgos.

7. Protocolo de contingencia

Escenario de falla

Durante una prueba autorizada, un escaneo o una validación podría generar carga inesperada, bloquear temporalmente un servicio del laboratorio o producir una modificación no prevista. Las pruebas de este informe no deben trasladarse a producción.

Impacto sobre la continuidad del negocio

En un entorno empresarial equivalente, una interrupción de HTTP/Tomcat podría afectar aplicaciones web; una interrupción de SMB, el acceso a archivos compartidos; y una interrupción de SSH, la administración remota. El impacto real depende de la arquitectura y no ha sido medido en el laboratorio.

Plan de respuesta

Activación: detener la prueba al observar degradación, errores repetidos o comportamiento inesperado. Contención en los primeros 15 minutos: detener herramientas, registrar hora, objetivo, comandos y síntomas; no lanzar más pruebas. Recuperación: avisar al responsable/docente, comprobar el estado del laboratorio y reanudar únicamente con autorización. Comunicación: informar el alcance, la duración, los síntomas y las acciones realizadas. Post-mortem: conservar registros, determinar causa raíz y documentar medidas preventivas.

RTO y RPO

Como valores de planificación académica, se propone RTO de 4 horas para restablecer el servicio de laboratorio y RPO de 24 horas para la recuperación de datos de configuración, sujetos a validación del responsable del sistema. Estos valores son propuestas, no objetivos medidos ni compromisos de INSECUR S.A.

8. Anexos y declaración ética

8.1. Bitácora y evidencias

Adjuntar, si existen y corresponden a la misma sesión: bitacora/nmap_inicial.txt; bitacora/nmap_puertos.txt; bitacora/gobuster_tomcat.txt; salidas de SMB saneadas; evidencia de validación de Tomcat Manager con secretos ocultos; captura de VPN; capturas de cada hallazgo; y cualquier registro posterior a la explotación que realmente se haya realizado. No referenciar archivos inexistentes como si fueran anexos incorporados.

8.2. Nombres de capturas

Usar nombres trazables a la fase y al hallazgo, por ejemplo: reconocimiento_VPN.png, escaneo_H-01.png, enumeracion_H-02.png, enumeracion_H-03.png y enumeracion_H-04.png. Asegurar que las capturas muestren el objetivo correcto y que no expongan contraseñas, tokens ni flags completas.

8.3. Flags y hashes

Si se obtuvieron flags dentro de la sala autorizada, conservarlas de acuerdo con las reglas de la plataforma y registrar únicamente su hash SHA-256 en el informe. Si no se obtuvieron, indicar «No aplica / no obtenida»; no fabricar hashes.

8.4. Declaración ética

Declaro que las actividades descritas en este informe se limitan al entorno académico autorizado de TryHackMe, que los resultados se documentan según la evidencia disponible y que no se pretende atribuir como confirmado ningún acceso o vulnerabilidad que no haya sido comprobado. Me comprometo a mantener la confidencialidad de credenciales, tokens y datos sensibles, y a comunicar cualquier incidente al responsable académico.

Firma

Estudiante: Felipe Villar Zuloaga

DNI: 46.063.333

Fecha: 8/10/26

Firma: _____